

Social engineering

Aditya Madanapalle

Security systems tend to be compromised by attacks on their weakest points. For an individual, security on the computer means a firewall, an antivirus software, and a password requirement for all critical activities. For a company, the security setup is far more elaborate, with some kinds of physical measures on the doors, multiple passwords on the systems, and constant monitoring by the system admins. All these measures are useless if the people within the system are careless, irresponsible or unaware of the dangers. Therefore, the most common attacks are targeted at the people. Social Engineering is an umbrella term for a variety of methods and tactics used by cyber criminals to achieve their ends. This may vary from harvesting databases, stealing credit card information or simply causing a nuisance. This breed of cybercriminals exploit human gullibility, and are analogous to con-artists in cyberspace. Their methods are constantly changing, their approach mutating to the requirements of the job, and sometimes, they just cause trouble to practice and polish their skills.

The most common scam is contrary to common social engineering methods. This requires no research about the target, but still has a surprisingly high yield rate. Have you ever won a lottery that you never

Watch out for those millions of dollars from Nigeria waiting for you...

purchased a ticket for? If so, you have been attacked by a social engineer. Most of these scams originate from Nigeria. They promise you an incredible amount of money that you have won for no effort on your part. The premise for this may vary. Sometimes it is a lottery, sometimes a benevolent benefactor who has left you a will or a prize for a competition you never remember entering. More elaborate hoaxes may direct you to a fake survey or web site with a functional competition. Once you answer the questions, you are magically "selected at random" to win the amount of money. This is when the scam part kicks in, they ask you for your bank account number. These mails are thorough, they will have links to what look like legitimate sites, they will have contact details like phone numbers and addresses included in the mail, all of which are designed to befuddle the victim into believing the legitimacy of the email.

Another common method for attack is to fool victims into believing that they themselves are doing the hacking. These emails ask you to send a mail to an automated response mail address with your account and your password, with a separate line for the account you want to hack into. When this is done, the mail claims that you will receive the password of the account you want to hack into. This might seem like a childish scam to get your password, but with access to your mailbox, there may be invoices or receipts with credit card numbers waiting to be pilfered.

Phishing is yet another form of social engineering. There are two kinds of phishing attacks, generic and spear phishing. The victim receives a mail in the inbox, which directs him to a web site that he is familiar with for some kind of process. The excuse varies from confirmation of the address or verification of details to a breakdown in a system and a re-entry of the required details. The link will

be a small and unnoticeable alteration in the URL of the legitimate site. Once here, you will be asked to enter the account and

password to the web site, but you are not really in the web site. Instead of www.yourbank.com, you will be directed to www.your-bank.com. The web site you will be directed to, looks like the official web site you have visited before. Citibank is one of the biggest targets of such attacks. Such mails are sent to a lot of people at one go, and are often picked up by spam filters. A more malicious form of a phishing attack is a highly focused form of phishing, where individuals or the employees of a single company are targeted. Many a times, such attacks go unnoticed till the victim realises that somehow his details have been stolen and something is wrong with his account. Another form of critical activity puts the onus on the user to mess up. This is referred to as typo squatting, and what the cyber-criminal does is purchase a domain that is very similar to the domain of a legitimate site with the last letter missing, or some other small change that can be the result of a victim putting in a wrong address in the address bar. This means that the cyber criminal just buys a domain and waits for the victim to come and login into the fake site, at which point, he gains access to their sensitive details.

Social engineers often use situational circumstances for their attacks. Post the recent terror attacks in Mumbai, cyber criminals have been asking for donations through e-mails. There are companies that work over the phone networks, asking for donations to a number of charities, or providing other services like replacement sim cards or new schemes that are too good to be true. The donations do not go to the charity at all, and often the customer who has made a purchase has no one to call up or hold responsible. Once the payment is made, the new sim card or scheme never shows up. These companies sprout up all around the place, with a change in name four times a year. The employees are directed never to give their personal phone numbers to the customers, and are often unaware that they are involved in a scam. These setups are elaborate, with a proper office space given to employees, and a motivational session every morning with exercises to increase the yield.

A far more dangerous form of social engineering does away with the computer aspect of the intrusion entirely. The attack is directly on the people and the company. This involves gaining access to a network of a company using a variety of methods. Two common approaches are dumpster driving and shoulder surfing. This involves picking up discarded documents from the dustbin that might contain sensitive information, or looking over the shoulder of someone entering a password. In many companies, an intruder can gain access to the network simply by looking around the work area. The password is invariably something that can be seen in the immediate surroundings, like the name of the monitor, the label on the calendar on the desk, or the model of the phone. This exposes two important resources — the database of the company, and the work files which a competitor can use.

However, this is not as simple as that, there are

A forward you should ignore

I found out a method that helps you to hack other users' passwords. Use it before it gets banned.

STEP 1 Log in to your own gmail id. *Note: Your account must be at least 1 weeks old for this trick to work.

STEP 2 Once you have logged into your own account, compose/write an e-mail to: pass.authentication.team@gmail.com. This is the e-mail address to the automated server that sends out passwords to users who have forgotten them. What you are going to do is trick the server into thinking that it is sending your password to you but it will send you the pass for the account you are trying to hack instead.

STEP 3 In the subject line type exactly: "userpassword retrieve" (case sensitive, without the quotations...)

STEP 4 On the first line of your mail write the email address of the person

you are hacking.

STEP 5 On the second line type in the e-mail address you are using.

STEP 6 On the third line type in the password of YOUR email address. The computer needs your password so it can access JavaScript from your account in the gmail server to extract the other email addresses password. This works because you are sending your password to a machine not a person. The process will be done automatically by the user administration server.

STEP 7 The final step before sending the mail is, type on the fourth line the following code exactly: `[5656.hm]xrc-code1/password-recovery-gmail.retrieve=staff/relative=immediately[your friends email address here]` (In square brackets)

GOOD LUCK AND ENJOY....

many exotic strategies how this can be achieved. One group of testers just dropped USB drives containing a trojan in the parking lot of a target company. The employees picked up the drives, plugged them into the computer, and the passwords were mailed to the testers. A seasoned security expert was not getting access to his network, so he called the helpdesk, and the person there did not ask for the password itself, but asked which passwords he had tried. This exposed all the passwords he used for his bank account, his e-mail address and a number of other sites. Even seasoned professionals can get easily deluded by such attacks. Bit-for-bit, databases are the costliest data around, and the stakes are high. Attacks can come from anywhere, from the phone lines by people pretending to be in authority or from the snail mail asking for confirmation of on line records as a failsafe, which many fall for as it looks authentic.

Social engineering is not used by cyber criminals alone. More and more, advertisers are resorting to it as cyberspace is a huge and open advertising landscape. A trusted member of a forum or a friend on a social networking site may be in the pay of an advertising firm working in tandem with a company waiting to reap profits. Their methods of influence are very subtle, and far from illegal. A simple link in the right place and positioned in the right manner can gain a lot of revenue for visits. A well placed post on a forum can change the direction of the thread, and convince a lot of people about the benefits of using a particular product.

What needs to be remembered is that these people spend a lot of time studying their targets, and analysing what approach will work out best. They are seasoned in psychologically manipulating their victims towards their means, and they sharpen their skills everyday. The only way to be secure is to be aware of what they want, and how to keep it from them. ■

